Day 2, tasks 5 to 8: guidance

Detail for TLS and keys, security case, architecture, and policy. The short schedule is in **`day2_checklist.md`**. The full steps are in **`build_guide_and_day2_plan.md`**.

Task 5: TLS and keys (25 min)

1. **Capture before (5).** Wireshark on Windows often cannot see **`localhost`**. Use the **Npcap Loopback Adapter**, or capture on the LAN IP. Send one note over plain HTTP. Screenshot the readable JSON.
2. **Certificate (3).** **`openssl req -x509 -newkey rsa:2048 -nodes -keyout <name>.key -out <name>.crt -days 365 -subj "/CN=<host>"`**. On XAMPP, OpenSSL is in **`xampp\apache\bin`**.
3. **Apache (5).** Edit **`xampp\apache\conf\extra\httpd-ssl.conf`**. Set **`SSLCertificateFile`** and **`SSLCertificateKeyFile`** (forward slashes). Restart Apache. If it will not start, read **`apache\logs\error.log`**. The usual cause is a wrong path.
4. **Capture after (4).** **`curl -k https://localhost/...`** (**`-k`** because the certificate is self-signed). Screenshot the unreadable body.
5. **HTTPS-only (3).** Set **`REQUIRE_HTTPS`** to **`true`** in **`sync.php`**. Re-run tests over HTTPS with **`sed 's/curl -s /curl -sk /' test_sync.sh > test_sync_tls.sh`**. Over plain HTTP the endpoint should now return 403.
6. **Revocation proof (3).** **`UPDATE api_tokens SET revoked=1 WHERE label='clinician';`** then repeat the request. Expect 401. Screenshot both results.

Key lifecycle table (starting points, adapt to what you did)

Key	Generated	Stored	Access	Rotated	Revoked	Protected by
TLS private key	OpenSSL on server	Server file, outside web root	Sysadmin only	Yearly, or on compromise	Replace cert (CA revocation in production)	File permissions. Gap: lab key has no passphrase
API token	**`random_bytes`**	SHA-256 hash only	Holder device	30-day expiry	**`revoked`** flag	TLS, hashing
BitLocker recovery key	At encryption	Directory or MDM, not on the device	IT helpdesk	After each use	Decrypt or re-key	Admin role

Key	Generated	Stored	Access	Rotated	Revoked	Protected by
SSH host keys	`crypto key generate rsa`	Router NVRAM	Admins	Yearly or on staff change	Zeroise key	Management ACL, enable secret
Admin passwords	At config	Hashed in config	IT admins	90 days or on staff change	Remove account	AAA, VTY ACL
Wi-Fi PSK	On the AP	Password manager	IT	Yearly or on loss	Change it	Gap: shared key, so WPA2-Enterprise in production

Tasks 6 and 7: security case and architecture (50 min)

Case (25)

1. Define it (5): lost devices holding cached notes. Use the four answers in the full guide.
2. Risk table (12): score likelihood and impact from 1 to 5 yourself. Worked example: lost unencrypted device about 4 x 5 = 20. With encryption, PIN and wipe, residual about 2 x 3 = 6.
3. Balance (8): use the trade-off table, then add three residual risks (one is a device lost inside the offline window).

Architecture (25)

1. Draw (12): 8 boxes, 3 trust boundaries, flows numbered 1 to 6, each labelled with its control.
2. Principles table (4): point each principle at something you built.
3. Attacker paths (5): four paths, each tied to your own evidence.
4. Big decisions (4): one rejected alternative each. Name the single points of failure (one router, one switch, one uplink).

Task 8: policy and legal (25 min, adapting an existing policy)

Check the legal points are current (5)

ICO: notify "where feasible within 72 hours"; tell individuals "without undue delay" if the risk is high. Use that wording, not a flat "72 hours".

DSPT: applies to organisations with access to NHS patient data and systems. Version 8.0.0 (1 August 2025) brought the NCSC Cyber Assessment Framework in for some providers, not clearly for a general social care provider. Hedge it.

The Data (Use and Access) Act 2025 is being commenced in stages. Check current ICO guidance before relying on a specific change.

Adapting your existing policy (10)

Keep (maps straight to the brief): passwords and MFA, BYOD and working from home (MDM, remote wipe), monitoring and logging, malware, removable media, change control, risk, training, incident and continuity.

Fix before using:

1. **Breach timing.** A 24-hour internal report is your own rule. Do not cite Article 33 for it. Article 33 is the notification to the ICO: where feasible within 72 hours.
2. **Monitoring.** Check the legal citation for monitoring staff. RIPA 2000 concerns interception, so check it is the right basis. The ICO's workplace monitoring guidance is the usual reference. Monitoring should be proportionate, with staff told and a DPIA done.
3. **Passwords.** Forced complexity rules sit awkwardly with current NCSC guidance, which favours length. Check it before quoting.
4. **ISO 27001 numbers.** The control numbers (A.12.4.1 and so on) are the 2013 Annex A. The 2022 edition renumbered it. Check before quoting.
5. **Review period.** "Bi-annually" is ambiguous. Say "every two years".
6. **Remove the old organisation's name and internal document references.**

Add for this brief (the existing policy does not cover these):

Offline cache: cache only the day's caseload, clear after confirmed sync, encrypt at rest, auto-wipe after N days offline.

Cryptography and key management: use the lifecycle table above.

API tokens: short-lived, scoped, stored as hashes.

Retention of visit notes.

Health data and the Caldicott principles.

Four policies to submit

Policy	Built from	Key rules
Mobile devices and remote wipe	BYOD and WFH section, plus new offline cache rules	Encryption, PIN, MDM, wipe, cache limits
Access control and authentication	Passwords and MFA section	MFA, lock-out, least privilege, review
Cryptography and key management	New (key lifecycle table)	TLS, key storage, rotation, revocation

Policy	Built from	Key rules
Incident and breach reporting	Incident section	24-hour internal, ICO within 72 hours where feasible

Evidence map (10)

Rule	Control	Evidence
Devices are encrypted	BitLocker	Topic 3 "after" file
Tokens can be revoked	**`revoked`** flag	Revocation test (5d)
Only HTTPS accepted	**`REQUIRE_HTTPS`**	HTTP 403 test
Management only from the admin VLAN	ACLs	Part A test table

Finish by naming the gaps (for example lab certificate, shared Wi-Fi key, no real MDM).

Sources

ICO: Personal data breach, https://ico.org.uk/for-organisations/report-a-breach/personal-data-breach/

NHS England: Data Security and Protection Toolkit (adult social care), https://adultsocialcare.standards.nhs.uk/published-standards/data-security-and-protection-toolkit